TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

COLLEGE NAME: KPR COLLEGE OF ARTS SCIENCE AND RESEARCH

DEPARTMENT: B.Sc. COMPUTER SCIENCE WITH DATA ANALYTICS

TEAM MEMBERS:

SNO	REGISTER NUMBER	NAME	COLLEGE	EMAIL ID
1	2328B0035	JENI JOSPHIN A (TEAM LEADER)	KPRCAS	23bda025@kprcas.ac.in
2	2328B0066	SARAVANAKUMAR P	KPRCAS	23bda056@kprcas.ac.in
3	2328B0068	SHREYAS S	KPRCAS	23bda058@kprcas.ac.in
4	2328B0016	BALAVIGNESH P	KPRCAS	23bda006@kprcas.ac.in
5	2328B0043	MAGUDESHWARAN G	KPRCAS	23bda033@kprcas.ac.in

USECASE SCENERIO:

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to log in to the company's Enterprise Resource Planning (ERP) system to complete monthly payroll processing. The employee connects remotely using a company-issued laptop. After opening the ZPA Client Connector, the user signs in through Azure Active Directory and completes multi-factor authentication (MFA).

The ZPA platform verifies the user's identity, confirms membership in the Finance_ERP_Users group, checks the device posture such as active antivirus protection and enabled disk encryption, and evaluates the connection environment. Once all policy conditions are satisfied, ZPA establishes a secure and isolated micro-tunnel that allows the user to access only the ERP application.

Through this connection, the accountant can perform payroll-related tasks within the ERP interface, while all other internal systems such as development servers and the HR database remain hidden and inaccessible.

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is engaged for a three-month development project and requires access solely to a particular Git repository hosted within the organization's internal infrastructure. The consultant is registered as a guest user in the organization's identity provider and assigned to the Project_X_Contractors group.

When the contractor connects through the ZPA client, the system authenticates the user and evaluates the device's security posture, including operating system patch status and firewall activation. ZPA policies allow the contractor to access only the Git repository using permitted protocols such as SSH (port 22) or HTTPS (port 443), and only during defined working hours between 9 AM and 5 PM.

This configuration enables the contractor to clone repositories, push updates, and pull code changes, while preventing access to other internal resources like the corporate intranet or shared file systems.

Scenario 3: Executive Access to Confidential Board Documents

A company executive needs to retrieve confidential board meeting materials stored in a protected folder on an internal file server. While traveling abroad, the executive attempts to access these documents using a tablet device. ZPA integrates with the organization's mobile device management (MDM) system to verify that the tablet meets required security standards, such as not being jailbroken, having encryption enabled, and maintaining an active device passcode.

After successful authentication, ZPA evaluates the defined access policy which requires the user to belong to the Executive_Board group, use an MDM-compliant device, and connect from a country listed in the organization's trusted allowlist. When these conditions are met, ZPA establishes a secure connection directly to the Board_Documents file share. All transmitted data is protected using TLS encryption, and any attempt to access other network resources or file shares is automatically denied and recorded.

Scenario 4: IT Administrator Access to Server Management Interfaces

A system administrator needs to perform routine maintenance on several servers using management protocols such as SSH for Linux systems and RDP for Windows systems. Instead of granting full VPN access to the management network, ZPA treats each server management interface as a separate application segment.

The administrator authenticates through the ZPA client and is presented only with the servers they are permitted to manage based on their assigned subgroup. For instance, members of the Linux_Admins group can view and access only Linux servers, while Windows_Admins are limited to Windows-based systems.

This approach prevents the administrator from scanning the network, accessing unauthorized servers, or connecting to ports that are not explicitly permitted.

Scenario 5: Mergers and Acquisitions Integration

After acquiring a smaller company, the parent organization needs to temporarily provide the acquired firm's HR team with access to the benefits enrollment application used internally. Users

from the acquired company are added as external collaborators within the identity provider and assigned to the Acquired_HR group with restricted attributes.

ZPA policies are configured to allow this group to access only the Benefits_App, which is hosted inside the parent company's internal environment. The external users install the ZPA client, authenticate using the identity provider, and are connected directly to the benefits application without gaining network-level connectivity.

Because access is limited strictly to the application layer, the broader internal infrastructure of the parent organization remains hidden. Once the integration process is completed and the users are migrated to the main identity system, the temporary access policies can be removed.

STAGE 1

OVERVIEW:

In today's digital environment, organizations face many cybersecurity threats when users access systems from different locations and devices. Traditional security methods that only rely on usernames and passwords are no longer sufficient to protect sensitive data.

This project focuses on designing and applying context-aware access control, which is a modern security approach that evaluates multiple factors before allowing access to an application. These factors include the user's identity, the security condition of the device, the location from which the user is accessing the system, and the risk level of the application.

The system analyzes these conditions in real time and decides whether to allow access, restrict certain actions, request additional authentication such as multi-factor authentication (MFA), or block the access completely.

The goal of this project is to improve cybersecurity by implementing a Zero Trust security model, where every access request is verified before granting permission. This helps organizations protect sensitive data, prevent unauthorized access, and ensure secure usage of applications from any device or location.

S. No.	VULNERBILITY NAME	CWE NO
1	Cross Site Scripting (Stored)	CWE-79
2	Broken Access Control	CWE-285
3	SQL Injection	CWE- 89
4	Broken Authentication	CWE- 285
5	Insecure Direct Object Reference	CWE- 639
6	Security Misconfiguration	CWE- 732
7	Cross Site Request Forgery	CWE- 352
8	Cleartext Transmission of Sensitive Information	CWE- 319
9	Clickjacking	CWE- 1021
10	Password Auto Completion Enabled	CWE- 310
11	DOM Based Cross Site Scripting	CWE- 79
12	JQuery Multiple XSS	CWE- 79
13	Information Exposure (HTTP Header Internal IP Disclosure)	CWE- 200
14	Information Exposure (SSL Issues)	CWE- 200
15	Information Exposure (HTTP Issues)	CWE- 200
16	OS Identification Failed	CWE- 200

1. **Vulnerability Name: Cross-Site Scripting (Stored)**

CWE Number: CWE-79

Description : Cross-Site Scripting (XSS) is a web security vulnerability where attackers insert malicious scripts into a web application. These scripts are stored in the server and later executed in the browser of other users who visit the affected page.

Business Impact : This vulnerability can allow attackers to steal sensitive information such as user credentials, session cookies, or personal data. It can also allow attackers to perform actions on behalf of legitimate users.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter: http://testfire.net/search.jsp?query='>alert('hacked')

Steps to Reproduce:

1. Open the website http://testfire.net/.
2. Navigate to the search box in the application.
3. Enter the script '>alert('hacked').
4. Submit the input.
5. A pop-up alert box appears showing “hacked”, confirming the XSS vulnerability.

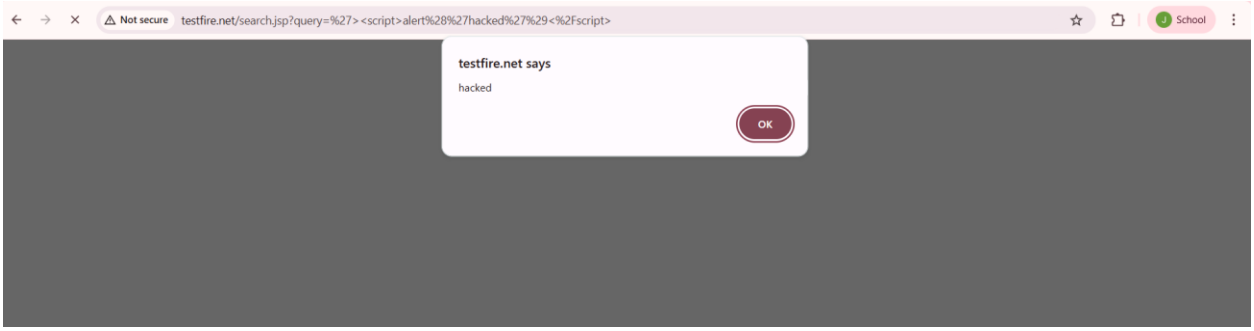
Recommendation:

Validate and sanitize all user inputs.

Use output encoding to prevent script execution.

Implement secure coding practices to prevent injection attacks.

Screenshot:



2. Vulnerability Name: Broken Access Control

CWE No: CWE-285

Description: Broken Access Control occurs when a system does not properly restrict users from accessing data or functions that they are not authorized to use.

Business Impact: Attackers may gain unauthorized access to sensitive data, modify user information, or perform administrative actions.

Vulnerability Path: http://testfire.net/login.jsp

Steps to Reproduce:

1. Open the website http://testfire.net/.
2. Try logging in using admin credentials.
3. Capture the request using Burp Suite.

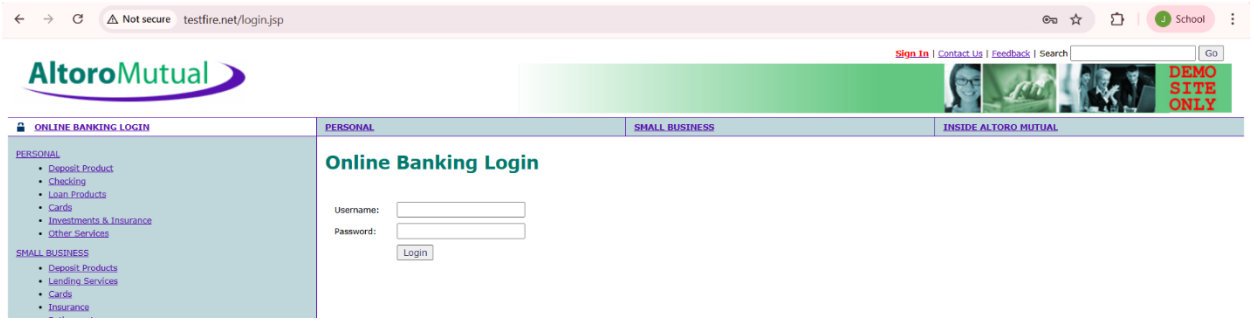
4. The request shows username and password in clear text.

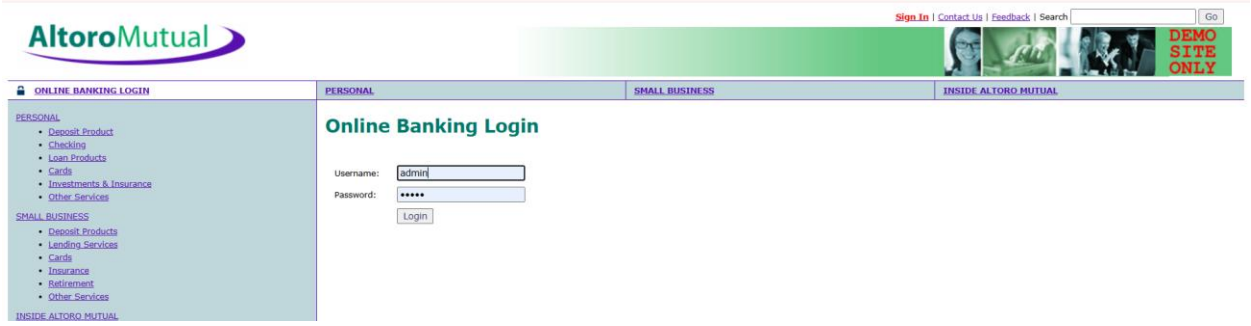
Recommendation:

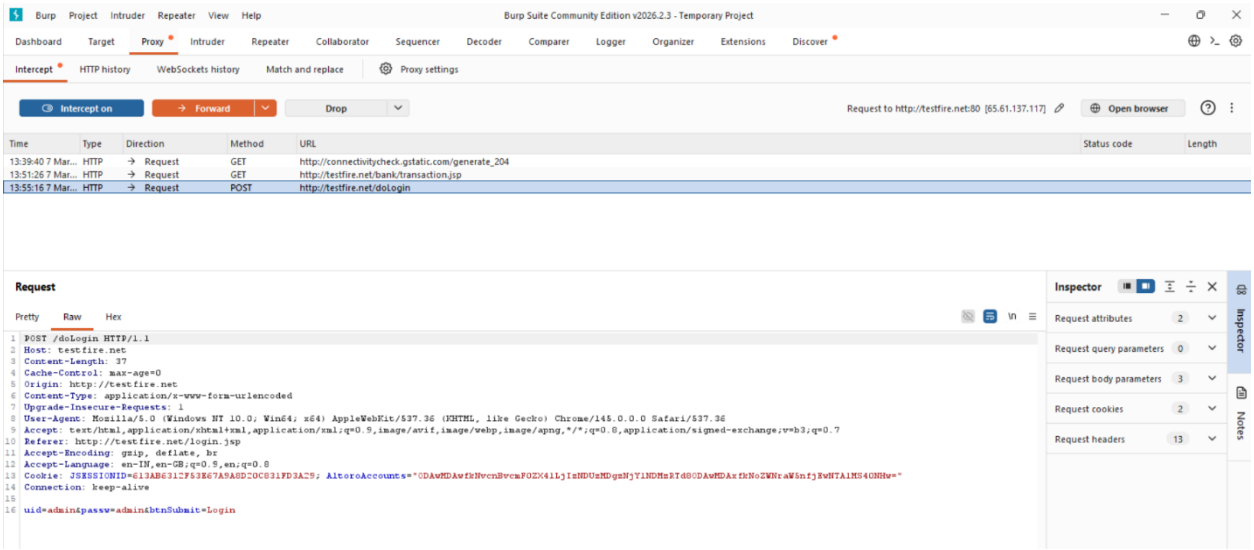
Implement strong authentication and authorization mechanisms.

Use secure session management to protect user access.

Screenshot:







3. Vulnerability Name: SQL Injection

CWE No: CWE-89

Description: SQL Injection occurs when an attacker inserts malicious SQL queries into input fields to manipulate the database.

Business Impact: Attackers can access sensitive data, modify database records, or gain unauthorized administrative access.

Vulnerability Path: http://testfire.net/login.jsp

Steps to Reproduce:

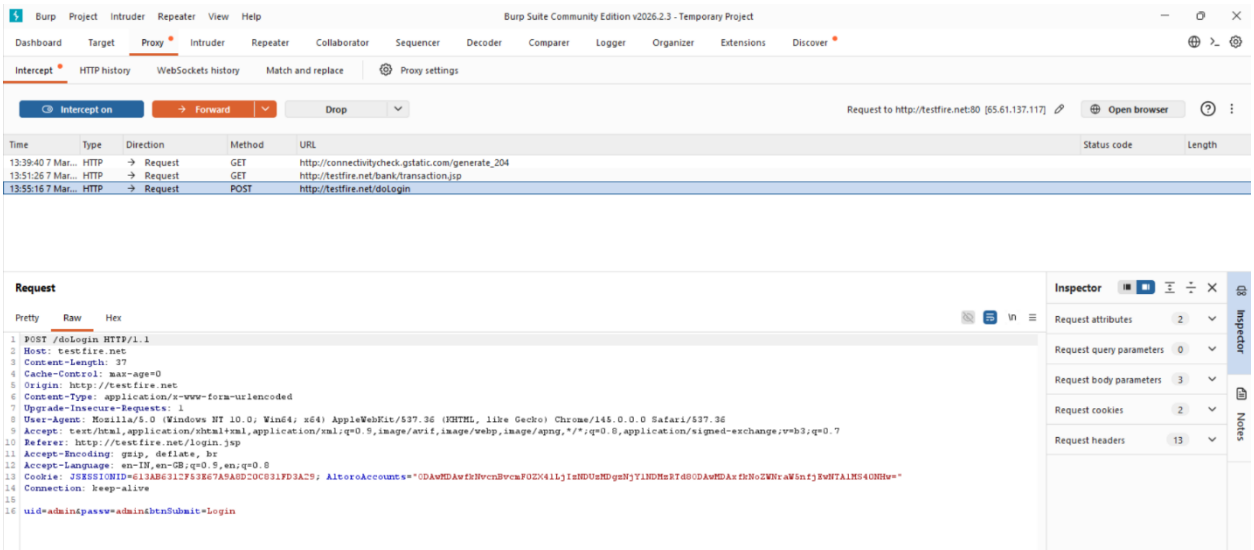
1. Open the website http://testfire.net/.
2. Enter SQL injection payload in the login form.
3. Capture the request using Burp Suite.
4. The attacker may gain admin access without a valid password.

Recommendation:

Use parameterized queries or prepared statements.

Validate and sanitize all user inputs.

Screenshot:



4. Vulnerability Name: Broken Authentication

CWE No: CWE-285

Description: Broken Authentication occurs when the system fails to properly manage user authentication. Attackers can bypass login mechanisms and access other user accounts.

Business Impact: Attackers may gain unauthorized access to user accounts and sensitive information.

Vulnerability Path: **http://testfire.net/login.jsp**

Steps to Reproduce:

1. Open the website **http://testfire.net/**.
2. Try logging in with manipulated username inputs.
3. Use SQL injection to bypass password verification.
4. Access to another user account is granted.

Recommendation:

Implement strong authentication mechanisms such as Multi-Factor Authentication (MFA).

Use secure password storage and proper session management.

Screenshot:

5. Vulnerability Name: Insecure Direct Object Reference (IDOR)

CWE No: CWE-639

Description: IDOR occurs when a web application allows users to access or modify data by changing object identifiers such as user IDs or parameters in the URL.

Business Impact: Attackers can access or modify sensitive information of other users without proper authorization.

Vulnerability Path: **http://testfire.net/bank/transfer.jsp**

Steps to Reproduce:

1. Open the website **http://testfire.net/**.
2. Login to the application.
3. Go to the “Transfer Money” section.

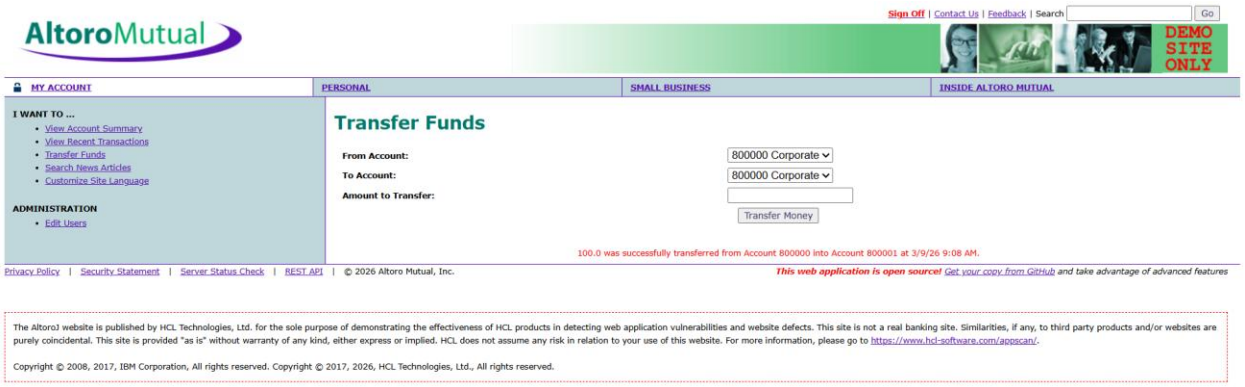
4. Intercept the request using Burp Suite and modify the transfer amount.

Recommendation:

Implement proper access control checks.

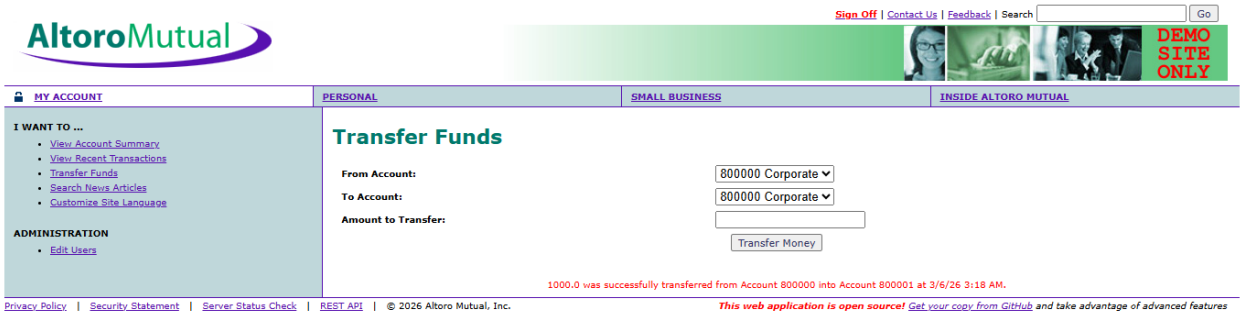
Validate user permissions before allowing access to sensitive data.

Screenshot:



The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.



The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

6. Vulnerability Name : Security Misconfiguration

CWE No : CWE-732

Description : Security Misconfiguration occurs when systems are not securely configured, allowing unauthorized access to sensitive files or directories.

Business Impact : Attackers may access confidential information, system files, or hidden directories due to weak security settings.

Vulnerability Path : **http://testfire.net/**

Steps to Reproduce :

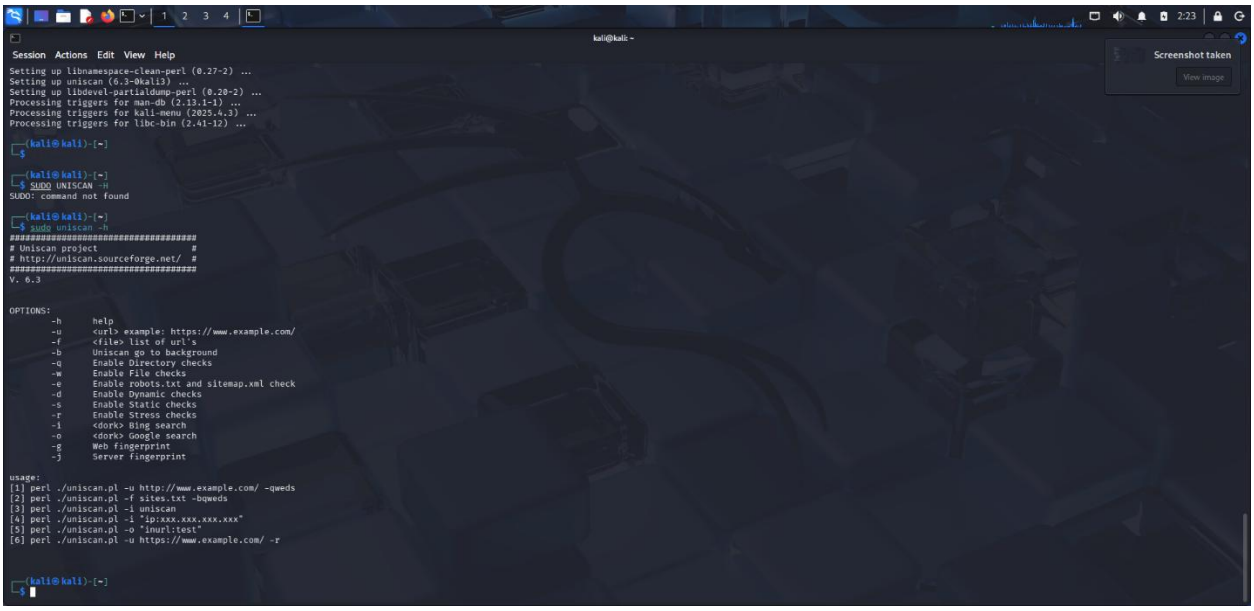
1. Open the website **http://testfire.net/**.
2. Use scanning tools such as Uniscan in Kali Linux.
3. Scan the website for hidden directories.
4. The scan reveals accessible directories and sensitive files.

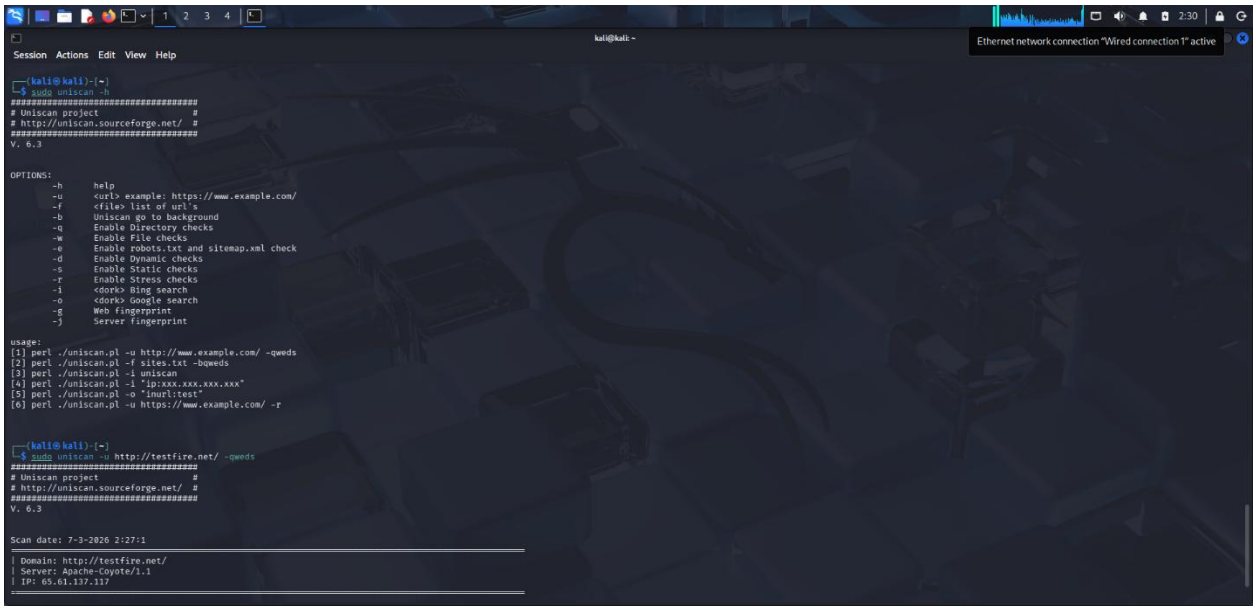
Recommendation :

Apply secure configuration settings for servers and applications.

Regularly perform security audits and vulnerability scans.

Screenshot :





7. **Vulnerability Name : Cross-Site Request Forgery (CSRF)**

CWE No : CWE-352

Description : CSRF is an attack that tricks a logged-in user into performing unwanted actions on a web application without their knowledge.

Business Impact : Attackers can perform actions such as transferring funds or changing user data using the victim's authenticated session.

Vulnerability Path : **http://testfire.net/bank/transfer.jsp**

Steps to Reproduce :

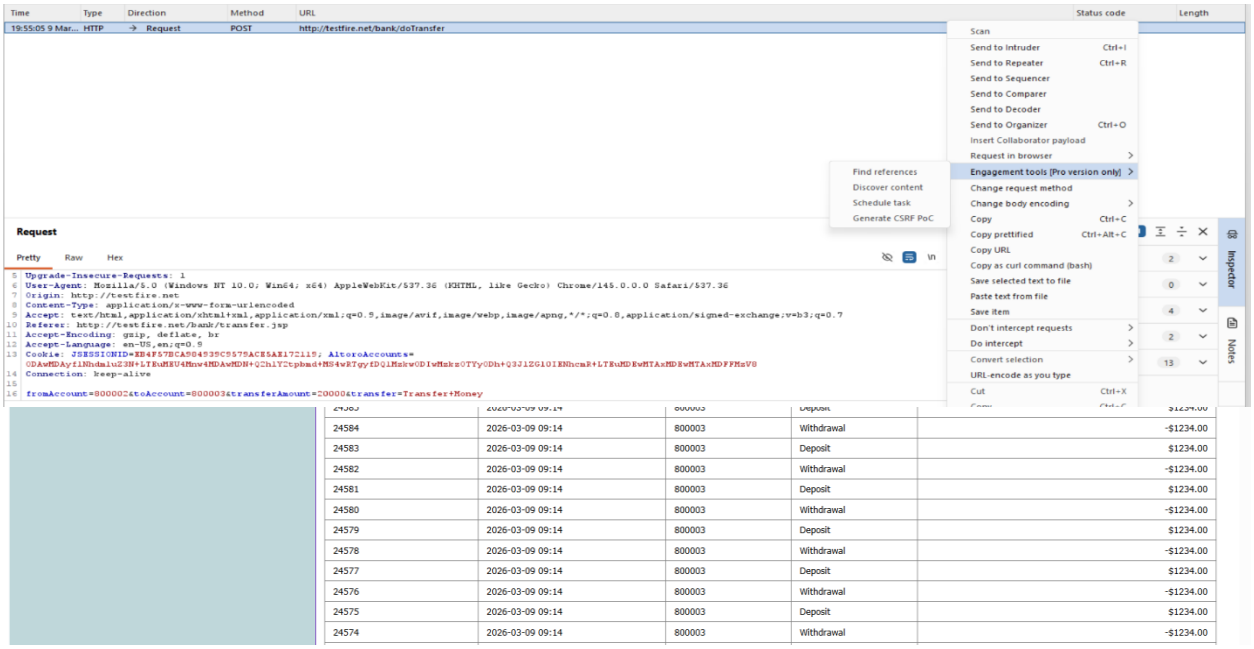
1. Open the website **http://testfire.net/**.
2. Login using valid credentials.
3. Capture the transfer request using Burp Suite.
4. Generate a CSRF proof-of-concept request to perform the action.

Recommendation :

Implement CSRF tokens to validate requests.

Use secure session management techniques.

Screenshot :



8. Vulnerability Name : Cleartext Transmission of Sensitive Information

CWE No : CWE-319

Description : This vulnerability occurs when sensitive information such as usernames and passwords is transmitted without encryption over the network.

Business Impact : Attackers can intercept network traffic and capture sensitive information, leading to data breaches and unauthorized access.

Vulnerability Path : http://testfire.net/login.jsp

Steps to Reproduce :

1. Open the website http://testfire.net/.

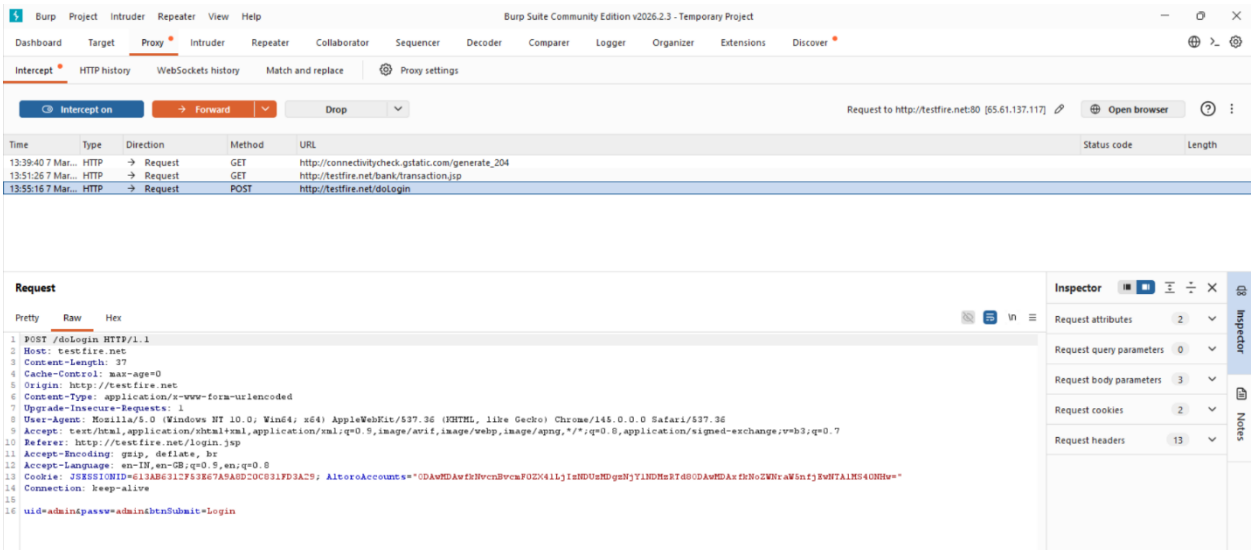
2. Login using admin credentials.
3. Capture the request using Burp Suite.
4. The username and password appear in clear text in the request.

Recommendation :

• Use HTTPS with SSL/TLS encryption.

• Ensure sensitive data is always transmitted securely.

Screenshot :



9. **Vulnerability Name : Clickjacking**

CWE No : CWE-1021

Description : Clickjacking occurs when a malicious webpage tricks users into clicking hidden buttons or links by placing the target webpage inside an invisible frame.

Business Impact : Attackers can trick users into performing unwanted actions such as clicking buttons, submitting forms, or revealing sensitive information.

Vulnerability Path : **http://testfire.net/**

Steps to Reproduce :

1. Open the target website **http://testfire.net/**.
2. Create an HTML page that loads the site inside an iframe.
3. Run the HTML file in a browser.

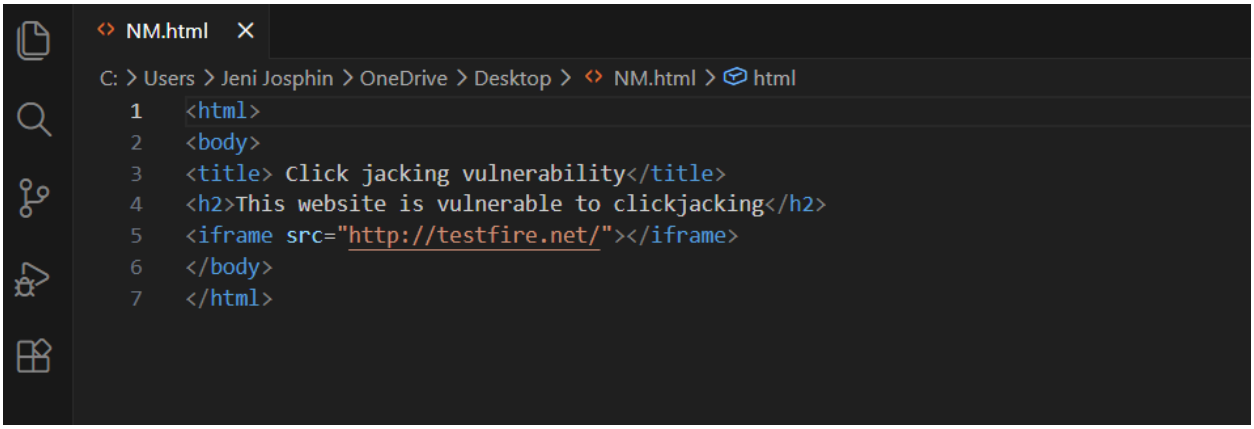
4. The website loads inside the frame, confirming the vulnerability.

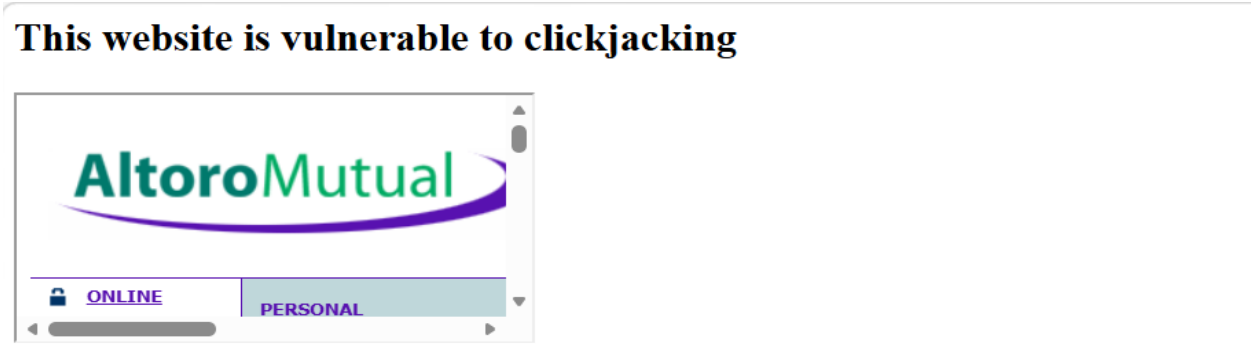
Recommendation :

Use X-Frame-Options header to prevent framing.

Implement Content Security Policy (CSP) to block unauthorized embedding.

Screenshot :





10. Vulnerability Name : Web Server Allows Password Auto-Completion

CWE No : CWE-310SSS

Description : This vulnerability occurs when the web browser automatically fills previously saved usernames and passwords on login pages.

Business Impact : Attackers who gain access to the device can easily view or use stored credentials to access the application.

Vulnerability Path : **http://testfire.net/login.jsp**

Steps to Reproduce :

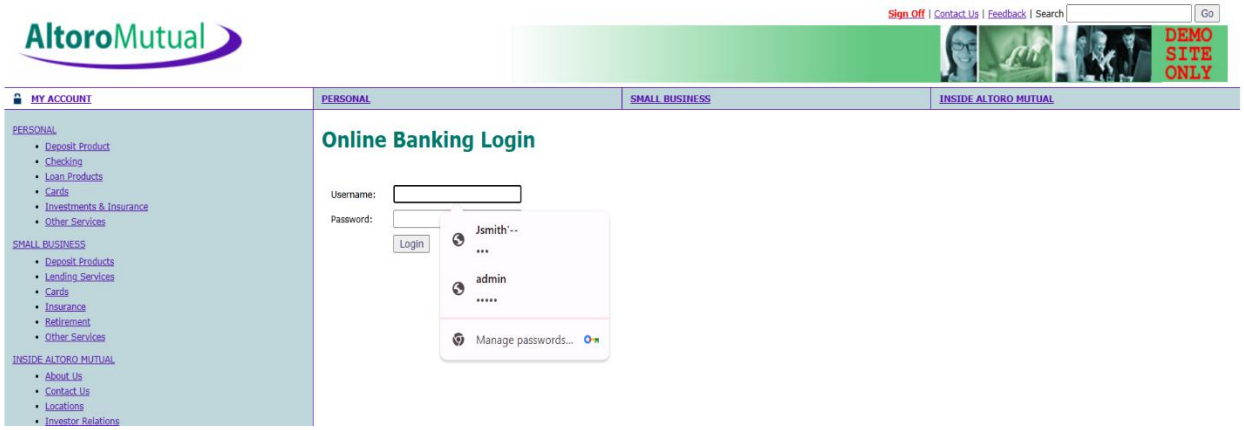
1. Open the website **http://testfire.net/**.
2. Navigate to the login page.
3. Click on the username or password field.
4. The browser automatically suggests stored credentials.

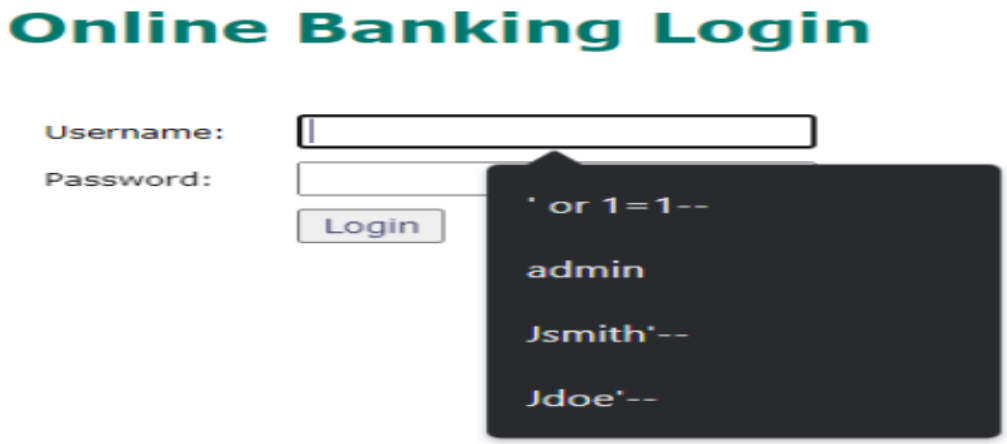
Recommendation :

Disable password auto-completion on login forms.

Use secure authentication mechanisms.

Screenshot :





11. Vulnerability Name : Cross-Site Scripting (DOM Based)

CWE No : CWE-79

Description : DOM-based XSS occurs when the client-side script processes user input and inserts it into the webpage without proper validation.

Business Impact : Attackers can execute malicious scripts in the user's browser and steal sensitive data such as session cookies.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

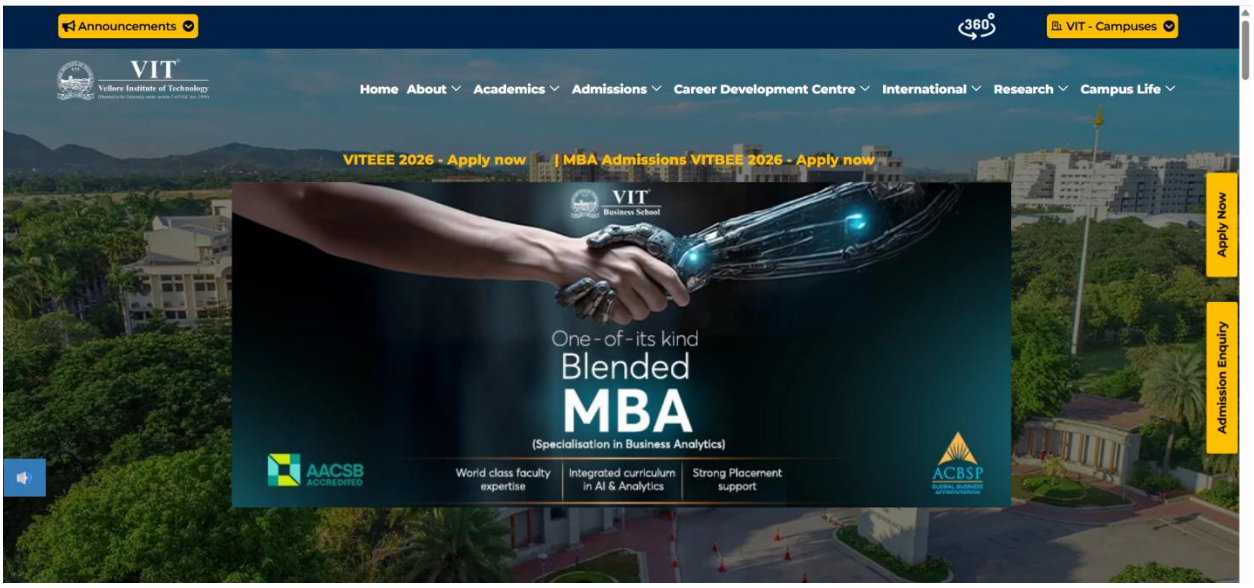
1. Open the website **https://vit.ac.in/**.
2. Inspect the page source using browser developer tools.
3. Identify places where user input is processed by JavaScript.
4. Inject malicious scripts to test for DOM manipulation.

Recommendation :

Validate and sanitize user inputs.

Avoid unsafe DOM manipulation methods.

Screenshot :



12. Vulnerability Name : JQuery Multiple XSS

CWE No : CWE-79

Description : This vulnerability occurs when outdated versions of JQuery contain security flaws that allow attackers to execute malicious scripts.

Business Impact : Attackers can exploit these vulnerabilities to run harmful scripts in the user's browser and steal sensitive data.

Vulnerability Path : **https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js**

Steps to Reproduce :

Open the website **https://vit.ac.in/**.

Access the JQuery script used by the website.

Identify the JQuery version in the source code.

Older JQuery versions may contain XSS vulnerabilities.

Recommendation :

Update JQuery to the latest secure version.

Regularly update libraries used in web applications.

Screenshot :

13. Vulnerability Name : Information Exposure (Web Server HTTP Header Internal IP Disclosure)

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals internal IP addresses or system information in HTTP response headers.

Business Impact : Attackers can use this internal information to identify the system structure and plan further attacks on the network.

Vulnerability Path : https://vit.ac.in/

Steps to Reproduce :

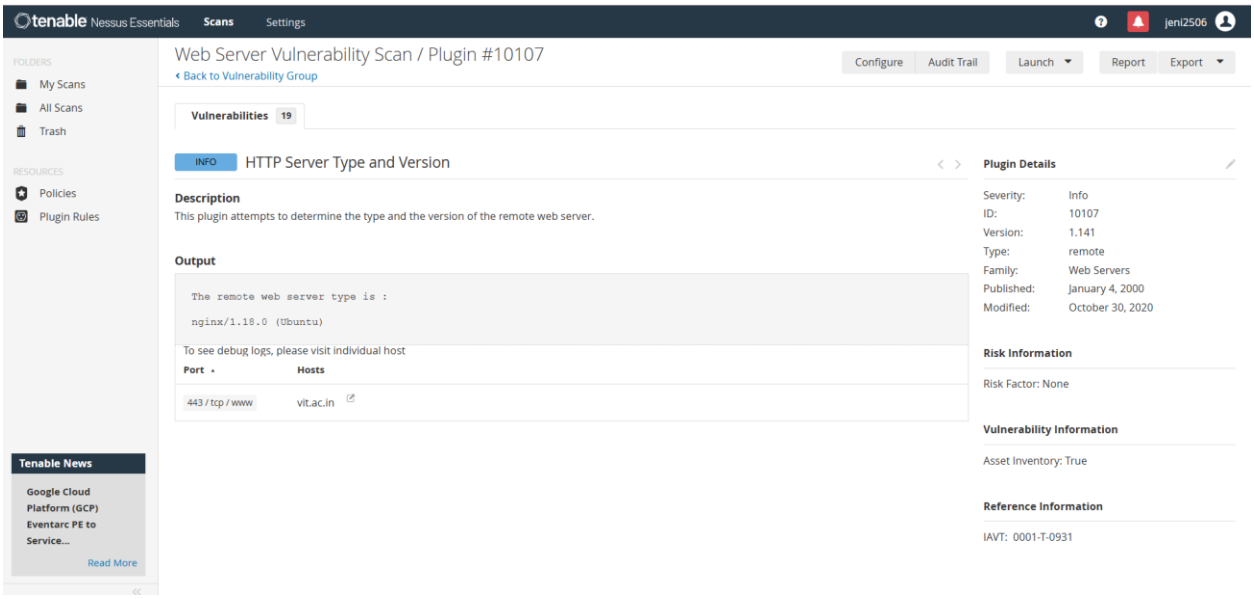
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the HTTP response headers.
4. The scan reveals the internal IP address of the server.

Recommendation :

Configure the web server to hide internal IP addresses.

Remove unnecessary information from HTTP response headers.

Screenshot :



14. Vulnerability Name : Information Exposure (SSL Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the SSL/TLS configuration of a website exposes sensitive encryption details or uses weak security protocols.

Business Impact : Weak SSL configurations can allow attackers to intercept encrypted communication and access sensitive data.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

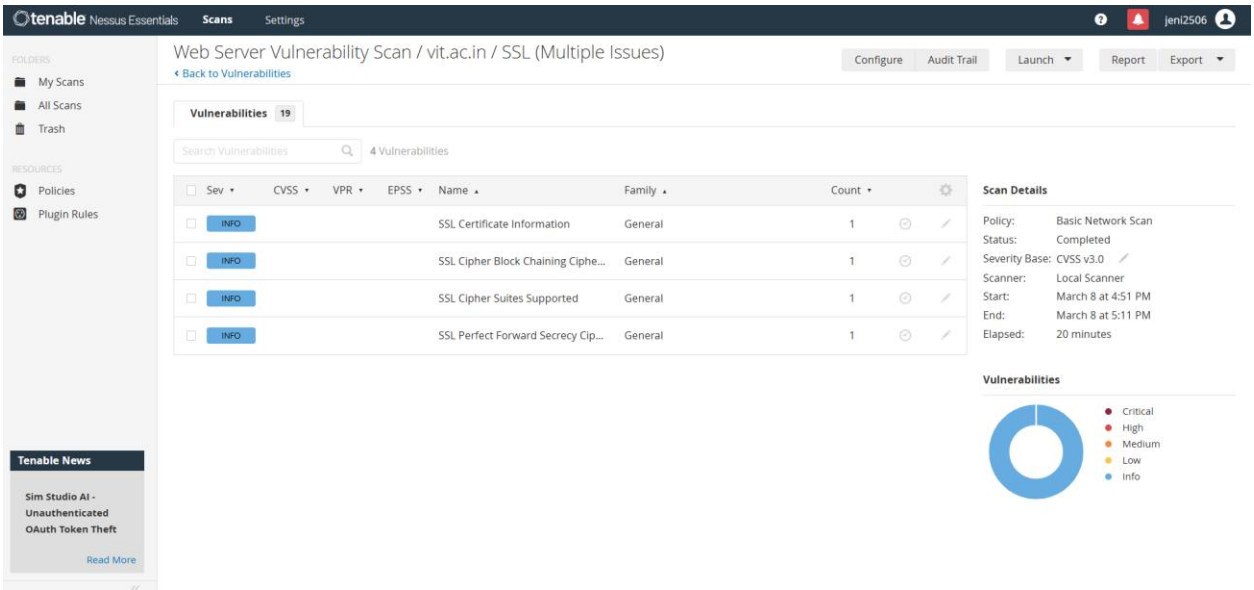
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the SSL/TLS configuration details.
4. The scan shows issues related to encryption protocols.

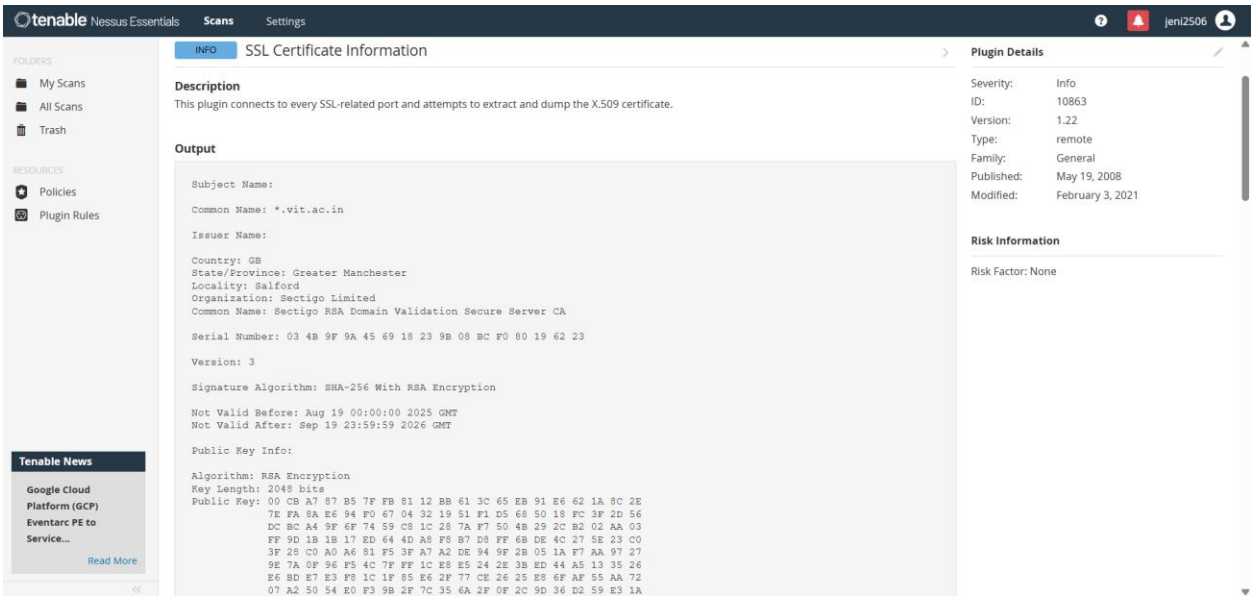
Recommendation :

Use strong encryption protocols such as TLS 1.2 or higher.

Disable outdated protocols like SSLv3.

Screenshot :





15. Vulnerability Name : Information Exposure (HTTP Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals unnecessary information through HTTP responses such as server details and protocol information.

Business Impact : Attackers can gather system information which may help them identify weaknesses and launch further attacks.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

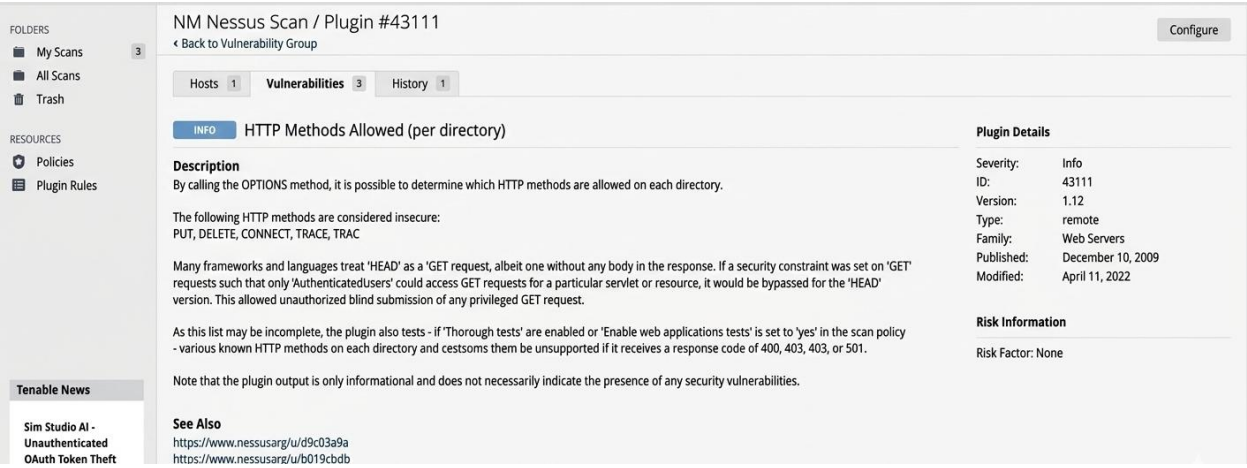
1. Open the target website.
2. Scan the website using Nessus scanner.
3. Review the HTTP response details.
4. The scan reveals server information and protocol details.

Recommendation :

Reduce unnecessary information in HTTP responses.

Use secure HTTPS configuration for communication.

Screenshot :



16. Vulnerability Name : OS Identification Failed

CWE No : CWE-200

Description : OS Identification Failed occurs when a vulnerability scanning tool cannot accurately detect the operating system of the target server.

Business Impact : Incorrect system identification may lead to improper security analysis and may hide potential vulnerabilities in the system.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

1. Open the target website.
2. Perform a vulnerability scan using Nessus scanner.
3. Analyze the scan results.
4. The scanner fails to identify the operating system of the target server.

Recommendation :

Ensure proper system configuration for accurate scanning.

Perform regular vulnerability assessments to detect security issues.

Screenshot :

STAGE 2

In this stage, vulnerability scanning and security analysis were performed to identify potential security weaknesses in the target web application. The objective of this stage is to detect vulnerabilities that may allow attackers to gain unauthorized access or expose sensitive information.

Security testing was conducted using vulnerability assessment tools such as Nessus Scanner along with manual analysis techniques. These tools help in scanning the web server, identifying vulnerabilities, and analyzing the security posture of the application.

The scan results provide information about different types of vulnerabilities along with their severity levels. The identified issues include Cross-Site Scripting, information exposure, and configuration-related vulnerabilities.

The following table shows the vulnerabilities detected during the scanning process.

S. No	Vulnerability Name	Severity	Plugin
1	Cross-Site Scripting (DOM Based XSS)	Medium	Multiple XSS
2	jQuery 1.3 < 3.5.0 Multiple XSS	Medium	CGI Abuse: XSS
3	Information Exposure (Web Server HTTP Header Internal IP Disclosure)	Low	Webserver HTTP Header Internal IP Disclosure
4	Information Exposure (SSL Multiple Issues)	Info	SSL Certificate Information
5	Information Exposure (HTTP Multiple Issues)	Info	HTTP Information
6	OS Identification Failed	Info	TCP/IP Remote Probing

STAGE 3

RESULTS AND SECURITY RECOMMENDATIONS

After completing the vulnerability scanning and analysis process, several security issues were identified in the target web application. The vulnerability assessment was performed using tools such as Nessus Scanner, Burp Suite, and manual testing techniques. The scan results revealed different types of vulnerabilities including Cross-Site Scripting (XSS), outdated JavaScript libraries, information exposure through HTTP headers, and configuration-related issues.

The vulnerability scan categorized the issues into different severity levels such as Medium, Low, and Informational. Medium-level vulnerabilities like DOM-Based Cross-Site Scripting and outdated jQuery versions can allow attackers to execute malicious scripts in the user's browser. These vulnerabilities can potentially lead to session hijacking, data theft, or unauthorized access.

Low-level vulnerabilities such as HTTP header internal IP disclosure may expose sensitive server details. Attackers can use this information to better understand the system architecture and plan further attacks on the web server.

Informational vulnerabilities including SSL certificate details, HTTP information disclosure, and OS identification failures provide additional information about the server environment. While these vulnerabilities may not directly lead to attacks, they can assist attackers in gathering intelligence about the system.

To improve the overall security of the application, several security recommendations are suggested. Web developers should implement proper input validation and output encoding to prevent injection attacks such as Cross-Site Scripting. Outdated libraries such as older versions of jQuery should be updated to the latest secure versions to eliminate known vulnerabilities.

Additionally, server configuration should be improved by hiding sensitive HTTP headers and internal IP addresses. Secure communication protocols such as HTTPS with strong SSL/TLS encryption should be used to protect data transmitted over the network. Regular security testing and vulnerability scanning should also be performed to identify new threats and ensure continuous protection of the system.

By implementing these security practices, organizations can significantly reduce the risk of cyberattacks and maintain a secure environment for users and applications.

TOOLS USED

The project involved the use of several cybersecurity tools and technologies to perform vulnerability scanning and security analysis. These tools help security professionals identify weaknesses in web applications and understand potential attack vectors.

Kali Linux : Kali Linux is a penetration testing operating system that contains a large collection of cybersecurity tools used for ethical hacking, vulnerability analysis, and network security testing. It provides an environment for performing security assessments on systems and web applications.

Nessus Vulnerability Scanner : Nessus is a widely used vulnerability scanning tool that detects security flaws, misconfigurations, and outdated software components in servers and web applications. It provides detailed reports that include vulnerability descriptions, severity levels, and remediation recommendations.

Burp Suite : Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests and responses between the browser and the web server. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting, and authentication issues.

Web Browser : A web browser such as Google Chrome or Mozilla Firefox is used to access the target web application and perform manual security testing. Browser developer tools help inspect web page elements and analyze scripts.

Uniscan Tool : Uniscan is a web vulnerability scanning tool used to detect hidden directories, configuration issues, and potential vulnerabilities in web applications.

These tools collectively help security analysts perform effective vulnerability assessments and improve the overall security posture of web applications.

CONCLUSION

The main objective of this project was to design and apply context-aware access control concepts while performing vulnerability assessment on web applications. With the rapid growth of digital technologies and online services, cybersecurity has become an essential requirement for protecting sensitive data and system resources.

Through this project, various web application vulnerabilities were identified and analyzed using security testing tools. The vulnerability scanning process helped in understanding how attackers

exploit weaknesses in web applications and how these vulnerabilities can impact the security of an organization.

The analysis revealed several vulnerabilities including Cross-Site Scripting, outdated software components, information exposure issues, and configuration weaknesses. Each vulnerability highlights the importance of implementing secure coding practices, proper system configuration, and regular security testing.

This project demonstrates the role of vulnerability assessment and security testing in improving application security. By identifying and addressing security weaknesses, organizations can prevent potential cyberattacks, protect user data, and maintain system integrity.

Overall, the project emphasizes the importance of proactive security measures, continuous monitoring, and regular vulnerability scanning to ensure a secure digital environment. Implementing strong security policies and modern access control mechanisms will help organizations protect their systems against evolving cyber threats.